

Secure Development Environment

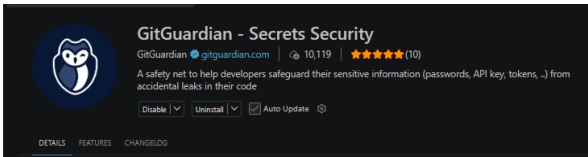
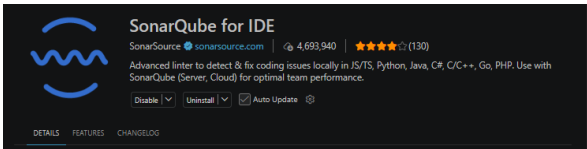
SSD1 Rubric 01 - implementation & evidence

Development tooling, secret protection, Git hygiene, and framework security

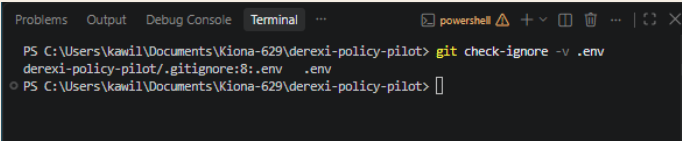
STATUS: COMPLETE*

This rubric item establishes a secure working baseline for DeRexi. The Windows VS Code workspace was documented with security-focused extensions, Git exclusion controls, and a hardened FastAPI CORS configuration. The evidence shows both the controls in place and the security change made to the application.

SECURITY TOOLING

	
GitGuardian - Secrets Security Installed and enabled in VS Code to help detect accidental exposure of passwords, API keys, tokens, and other sensitive values.	SonarQube for IDE (SonarLint) Installed and enabled for local static analysis so code-quality and security issues can be surfaced during development.

GIT & SECRET PROTECTION

	Behavior verified - without exposing secrets. The terminal command <code>git check-ignore -v .env</code> confirms that the project's <code>.gitignore</code> rule actively excludes <code>.env</code>. This verifies the protection without opening the environment file or displaying credentials.
---	--

01 IDE VS Code workspace	02 SCAN SonarQube analysis	03 SECRETS GitGuardian protection	04 GIT <code>.env</code> excluded
---	---	--	--

Framework Security Hardening

FastAPI CORS - before, remediation, after

The original middleware used wildcard values for origins, methods, and headers. For the SSD1 security baseline, the configuration was narrowed to the local DeRexi development origins and to the HTTP methods and request headers currently expected by the application.

BEFORE	AFTER
<pre>53 app = FastAPI(54 title="DeRexi: Policy Pilot API", 55 description="Policy governance and incident assistance for Aurum Capital Bank.", 56 version="0.4.0", 57) 58 59 app.add_middleware(60 CORSMiddleware, 61 allow_origins=["*"], 62 allow_credentials=True, 63 allow_methods=["*"], 64 allow_headers=["*"], 65)</pre>	<pre>58 59 app.add_middleware(60 CORSMiddleware, 61 allow_origins=[62 "http://127.0.0.1:8000", 63 "http://localhost:8000", 64], 65 allow_credentials=True, 66 allow_methods=["GET", "POST", "PATCH"], 67 allow_headers=["Content-Type", "Authorization"], 68) 69</pre>
Permissive development setting Wildcard origins, methods, and headers permitted broader cross-origin access than DeRexi requires.	Restricted development setting Local origins are explicit; methods are GET, POST, and PATCH; headers are limited to Content-Type and Authorization.

SECURITY PRINCIPLE

Least privilege - allow only the cross-origin access the application needs instead of granting blanket access.

RUBRIC COVERAGE

REQUIREMENT	DOCUMENTED EVIDENCE	RESULT
VS Code + security extensions	GitGuardian and SonarQube for IDE installed/enabled	MET
Git security configuration	Project .gitignore actively excludes .env	MET
Basic web-framework security	FastAPI CORS changed from wildcard to explicit local policy	MET
Supporting documentation	Screenshots document tool state, Git behavior, and before/after code	MET

IMPLEMENTATION OUTCOME

DeRexi now has a documented secure-development baseline. The project combines IDE security tooling, source-control protection for environment secrets, and a more restrictive FastAPI CORS policy. The CORS change is source-level evidence on this Windows copy; runtime validation remains to be performed in a configured DeRexi Python environment before it is described as tested.

*The updated CORS policy has not yet been runtime-tested on this Windows machine because its local Python environment does not currently contain the DeRexi runtime dependencies.